web UI rather than an API), two technologies are worth mentioning as they provide significant hardening against XSS:

- The *Content-Security-Policy* header (CSP), mentioned briefly in chapter 2, provides fine-grained control over which scripts and other resources can be loaded by a page and what they are allowed to do. Mozilla Developer Network has a good introduction to CSP: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
- An experimental proposal from Google called *Trusted Types* aims to completely eliminate *DOM-based XSS* attacks. DOM-based XSS occurs when trusted JavaScript code accidentally allows user-supplied HTML to be injected into the DOM, such as when assigning user input to the `.innerHTML` attribute of an existing element. DOM-based XSS is notoriously difficult to prevent as there are many ways that this can occur, not all of which are obvious from inspection. The Trusted Types proposal allows policies to be installed that prevent arbitrary strings from being assigned to these vulnerable attributes. See https://developers.google.com/web/updates/2019/02/trusted-types for more information.

EXERCISES

2. Which one of the following is a secure way to generate a random token ID?

a) Base64-encoding the user's name plus a counter.